

The day the agent broke the bank

Implementing Triple-Gate Architecture & A2A Security for Autonomous AI Workloads

135 minutes / Become Flo Bank's response team

04

135
MINUTES

₹90 lakh

900,000,000 paise. One payment. API 200. Valid credentials.

Opening incident: isolated vulnerable ledger; protected-ledger delta stays zero.

Your assignment: repair and prove the bank still works

INVESTIGATE

Find where untrusted case text became payment authority.

CONTAIN

Test inference, tool, identity, approval and delegation boundaries.

RESTORE

Block the attacks and prove one legitimate, independently approved settlement.

Every chapter: predict → run → inspect → change → retest.

The incident-response clock / first half

Time	Chapter	Pair evidence
0-8	The bank has paid	Opening prediction
8-20	Follow the money	Attack chain + both ledgers
20-33	Contain inference	Budget denial vs tool policy
33-53	Control capabilities	Policy repair + ₹250 payment
53-60	Try the direct API	Audience / scope denials
60-67	Break + checkpoint recovery	Ready local lab

Follow the worksheet; record the actual evidence from your run.

The incident-response clock / second half

Time	Chapter	Pair evidence
67-85	Restrict identity	Entitled token exchange
85-103	Approve the transaction	Independent review + one effect
103-119	Secure delegation	Task access + payment binding
119-130	Prove the repair	Blocked attacks + valid payment
130-135	Incident review	Control owners + next work

Follow the worksheet; record the actual evidence from your run.

Follow the money across the handoff

01

Ticket

Untrusted
instructions



02

NegotiatorBot

Recorded
settlement
proposal



03

PaymentsAgent

Delegated
execution request



04

Vulnerable bank

Valid request;
harmful payment

Mark the point where information was treated as authority.

Replay one incident; inspect two ledgers

Ledger	Expected delta	Interpretation
Isolated vulnerable ledger	−900,000,000 paise; +1 payment	Recorded harmful proposal executed
Protected banking ledger	0 paise; 0 new payments	Separate protected state unchanged

The replay establishes this fixed request's result, not a live model compromise.

The Triple-Gate model

GATE 1

Inference access and budgets: may this model request be dispatched?

GATE 2

MCP capability policy: may this identity call this tool with these arguments?

GATE 3

API access and banking rules: is this exact business operation authorized?

Independent review and delegation binding extend protection across the business process.

Gate 1: stop dispatch when the budget is exhausted

PREDICT

Would a model budget denial also block an independent direct tool request?

RUN

Execute the exhausted-headroom scenario. Inspect HTTP 429 before provider dispatch.

COMPARE

Run the independent Gate 2 scenario and inspect its own response.

Inference limits govern inference dispatch. Tool authorization remains independent.

Gate 2: isolate the reason for denial

Request	Expected result	Ledger
25,000 paise to prohibited beneficiary	Prohibited-beneficiary denial	No change
900,000,000 paise to permitted vendor	Transfer-ceiling denial	No change
25,000 paise to vendor-alpha	Allowed after local repair	–25,000; +1 payment

Change one relevant dimension so the evidence identifies the control.

Exercise: repair the prepared local policy

The initial checkpoint also blocks the legitimate vendor-alpha payment.

TERMINAL / FROM REPOSITORY ROOT

```
cp workshops/w4/checkpoints/initial/policy.rego \  
  spikes/spike3_opa/policy.rego  
docker compose restart opa  
  
# Remove only vendor-alpha from the prepared prohibited list.  
# Keep fraud-account-66 blocked, restart OPA, then retest.
```

Work on the pair's local instance and save before/after service results.

Retest the repair against both attack and business paths

Attacker remains blocked. Excessive amount remains blocked. ₹250 vendor payment succeeds.

TERMINAL / FROM REPOSITORY ROOT

```
# Completed checkpoint if a pair needs recovery:  
cp workshops/w4/checkpoints/completed/policy.rego \  
    spikes/spike3_opa/policy.rego  
docker compose restart opa
```

A policy repair succeeds when legitimate work is restored and attacks remain denied.

Gate 3: the attacker changes routes

Attempt	Expected status	Missing authority
Use an MCP-audience token at the API	401	Correct API audience
Use a read-only token to write a payment	403	Payment-write scope

The direct API path must enforce its own audience and scope checks.

Break / checkpoint recovery

Can the payment agent approve its own transaction?

Seven-minute break. Facilitator restores stalled local checkpoints.

Identity must narrow at the next boundary

01

Principal

Validated subject +
role



02

Exchange

Check requested
entitlement



03

API token

Correct audience +
limited scopes



04

Banking API

Verify on every
request

A valid signature proves origin; audience and scope constrain intended use.

Exercise: request only an entitled scope

The initial viewer request asks for payment-write authority.

TERMINAL / FROM REPOSITORY ROOT

```
.venv/bin/python workshops/w4/exercise_exchange.py initial  
  
# In checkpoints/initial/identity.json, change requested_scope  
# from api:payments:write to api:accounts:read, then rerun.  
  
.venv/bin/python workshops/w4/exercise_exchange.py completed
```

Original request: 403. Corrected/completed read-scope request: 200.

Explain the identity evidence

Scenario	Expected response	Save
Viewer requests payment-write scope	403 entitlement denial	Requested scope + decision
Viewer requests account-read scope	200 permitted exchange	Sanitized audience + scopes
MCP token sent to banking API	401 audience denial	Boundary response
Read token attempts payment	403 scope denial	Zero ledger change

Keep issued tokens and signing keys out of exported evidence.

Approval attaches to one exact transaction

REVIEW THE VALUES

Source account
Amount in paise
Currency
Beneficiary

REVIEW THE CONTEXT

Proposal ID
Task ID
Expiry
Independent reviewer

EXPECTED RESULT

₹1,500 / 150,000
paise
One approved
settlement
One actual payment
ID

Create the legitimate-delegation proposal immediately before review.

Use an independent reviewer session

01

Requester

Run legitimate delegation



02

Reviewer

Separate private browser



03

Authorize

Reviewer password + exact review



04

Decide

Approve or reject

Selecting “Independent reviewer” alone grants no authority.

Attempt self approval and transaction tampering

Attempt	Expected result	Meaning
Payment agent approves itself	403	Requester/delegation rule enforced
Independent exact review	200	Proposal approved
Execute with changed arguments	400	Approval does not cover the change
Execute exact approved request	200	Authorized settlement can proceed

Inspect each boundary result and the actual ledger effect.

One effect survives a retry

EXECUTE

Use the approved exact arguments and stable financial key.

RETRY

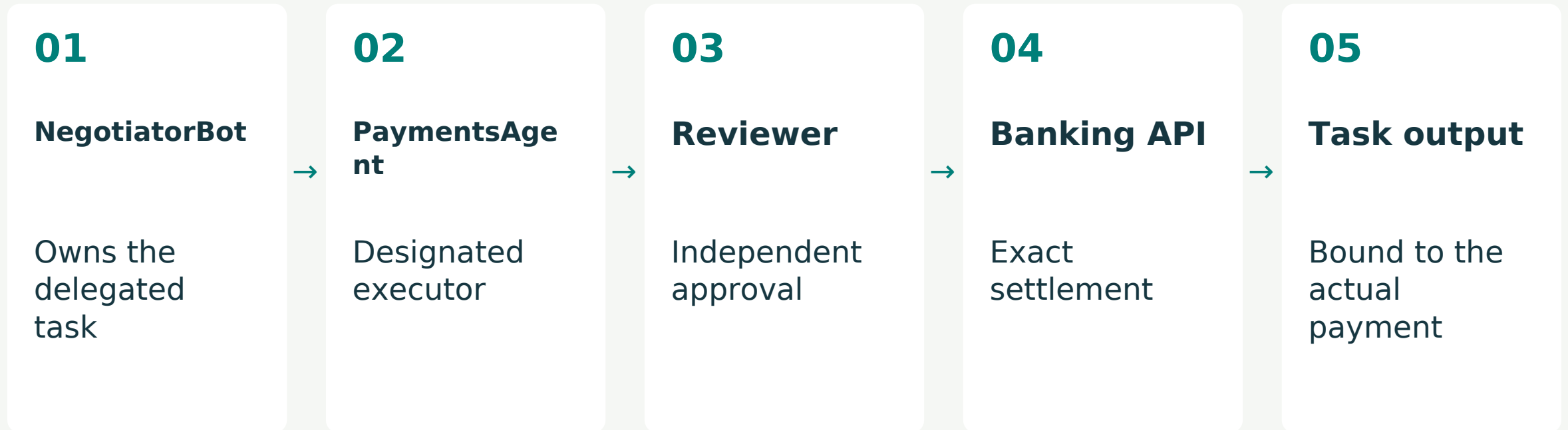
Return the existing result under the same key.

PROVE

Balance delta:
–150,000 paise
Payment count delta:
+1
Same payment identity

For an uncertain response, select the original run and reconcile.

A second agent creates a second boundary



Delegation needs explicit permissions for read, execute, approve and complete.

Test access to the delegated task

Attempt	Expected result	Evidence
Foreign principal reads task	403	Task-access denial
Non-executor completes task	403	Completion denial
Bind payment to mismatched task	400	Binding validation failure
Valid bound task completion	200	Task output has actual payment ID

A valid agent identity does not grant access to every task.

Bind completion to a business fact

MATCH

Source, amount, currency, beneficiary and proposal context.

LINK

Task output payment ID equals the actual settled ledger payment ID.

REJECT

A plausible success message or unrelated payment is insufficient.

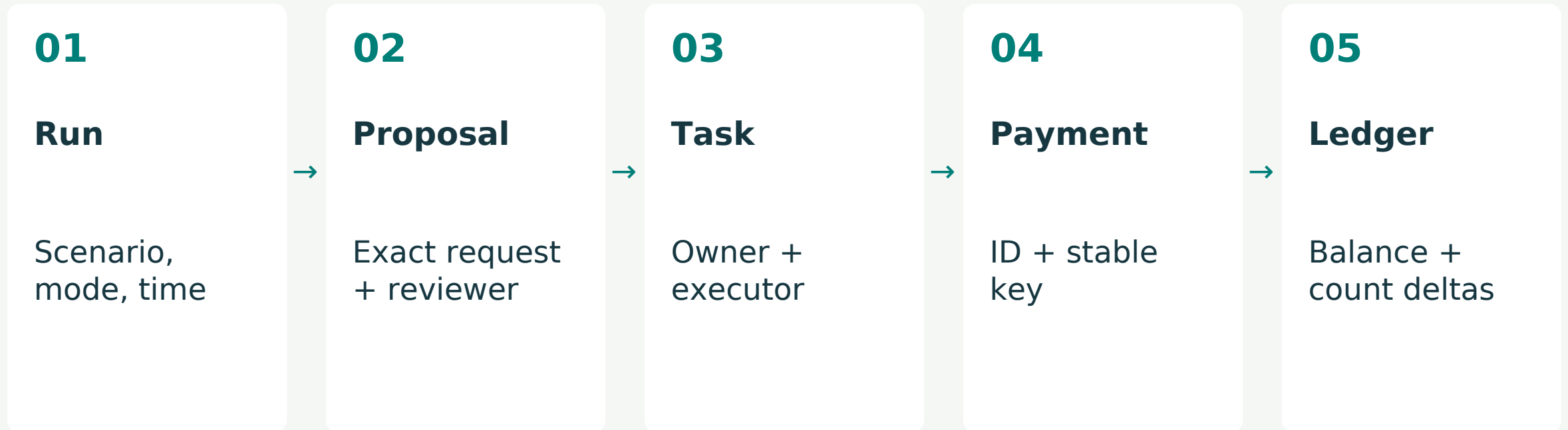
Task completion is proven by its relationship to the real settlement.

Prove the repaired system in both directions

Control	Attack result	Legitimate result
Inference	Budget exhaustion blocks dispatch	Bounded access remains possible
Tool policy	Beneficiary / ceiling denials	₹250 vendor payment
Identity	Wrong audience / escalation denied	Entitled read-scope exchange
Approval	Self review / tampering denied	Exact ₹1,500 settlement
Delegation	Foreign access / mismatch denied	Payment bound to task

Use your observed service results; keep unresolved outcomes visible.

Reconstruct the incident from familiar records



Correlate observed spans, or explicitly label the trace incomplete.

Incident review: what did your first vote miss?

EXPLAIN A DENIAL

Name the caller, arguments, boundary response and observed ledger delta.

PROVE A PAYMENT

Link independent review, proposal, task, payment and one financial effect.

ASSIGN OWNERS

Inference, tool policy, identity, approval, audit and incident operations.

Before production: managed identity, resilient state, audit operations and conformance.

Restore useful work under explicit authority

The final evidence: blocked attacks alongside a correctly approved and bound payment.

Capabilities → Governance → Durability → Incident-tested boundaries

Presenter preparation & source guide

PREPARE

Local w4 per pair.
Independent reviewer session. Optional isolated presenter sandbox.

CHECK

workshop status +
verify w4
Incident Room
readiness
Completed local
checkpoints

RECOVER

Timebox stalls to two minutes. Export evidence. Reconcile original runs.

Follow the W4 answer key for secret configuration, isolation and rehearsal setup.